

RealtouchHR

Super Admin Platform Owner Control Plane

Production-Ready Feature Specification and Codex/Developer Prompt

Purpose

This document defines the Super Admin portal for RealtouchHR as the platform-owner control plane. It is separate from company admin access and must manage the entire multi-tenant application, including companies, users, billing, plans, feature flags, security, emergency controls, audit logs, subscriptions, sandbox/live environments, compliance modules, and production operations.

Area	Requirement
Portal route	Use a protected route such as /superadmin or /platform-admin, separate from normal company workspaces.
Access model	Only designated platform-owner emails and authorised internal operators can access it. Company admins must never inherit access.
Purpose	Control the entire RealtouchHR SaaS platform across all tenants/companies.
Security level	Highest security zone with mandatory MFA, allowlist checks, session controls, audit logs, and emergency protection.
Implementation method	Audit existing implementation first, then implement missing features safely and production-ready.

1. Executive Summary

The Super Admin portal is the platform-owner control plane for RealtouchHR. It must be clearly separated from the Company Admin portal. A company admin controls only their own company workspace, but Super Admin controls the whole SaaS application, including every company account, subscription, feature entitlement, system flag, environment state, platform security setting, billing status, audit record, and emergency action.

This document should be given to Codex or the software developer to first audit the current RealtouchHR implementation and then implement a complete, secure, production-ready Super Admin layer.

2. Key Principle: Super Admin is Not Company Admin

Control Area	Company Admin	Super Admin / Platform Owner
Scope	One company workspace only	Entire RealtouchHR platform across all companies
Users	Invite/manage users within own company	View/manage users across all tenants where permitted
Features	Enable/disable company-level features allowed by plan	Create plans, control feature flags, override entitlements, enable/disable modules globally
Billing	View/manage own company subscription	View/manage platform billing, trials, paid subs, plan assignments, premium entitlements
Compliance	Run own company compliance checks	Monitor platform-level adoption, failed scans, premium gating, support/debug state
Security	Manage own company security policies	Control platform access, designated Super Admin emails, MFA policy, emergency kill switch
Data access	Company tenant only	Strictly controlled cross-tenant access with reason, time limit, audit log, and break-glass controls
Audit log	Company-level audit trail	Platform-wide audit trail and immutable super admin actions

Non-negotiable separation

A company owner, HR admin, payroll admin, or normal user must not be able to reach the Super Admin portal by role escalation, URL guessing, API calls, browser local storage modification, or client-side route manipulation.

3. Required Portal Access Design

- Expose Super Admin through a separate protected route such as <https://realtouchhr.com/superadmin> or <https://admin.realtouchhr.com>.
- Do not show the Super Admin sidebar link to normal company users or company admins unless their email is explicitly designated as a platform operator.
- Validate access on the backend for every page load, API call, mutation, export, and emergency action.
- Use a server-side designated email allowlist and/or platform_operator table, not only frontend checks.

- Require MFA for all Super Admin accounts before access is granted.
- Block access from unverified emails, inactive accounts, deleted users, suspended users, and unsupported authentication methods.

Security Requirement	Implementation Detail
Designated emails only	Only emails in SUPER_ADMIN_EMAILS environment variable or platform_operators table can access.
Backend enforcement	Every super admin route/API must call requireSuperAdmin() or equivalent middleware.
MFA required	Enforce MFA before loading portal or executing actions.
Session hardening	Shorter session timeout for Super Admin, device/session visibility, forced logout support.
IP allowlist optional	Allow configuration for trusted IP ranges if required.
Break-glass account	Optional emergency platform owner account stored securely with enhanced logging.
No client-only trust	Never rely on hidden menus or frontend route guards alone.

4. Audit-First Requirement Before Implementation

Before adding or changing features, the developer/Codex must audit the current application and produce an implementation gap report. The audit must identify what already exists, what is incomplete, what is insecure, and what needs to be built.

1. Scan all current frontend routes, sidebar modules, protected routes, and API endpoints.
2. Identify all existing roles and permissions: owner, admin, HR admin, payroll admin, manager, employee, auditor, super admin, and any hidden roles.
3. Check whether Super Admin access is currently enforced on the backend or only hidden in the UI.
4. Check whether any company admin can access /superadmin by URL or API call.
5. Audit data isolation between tenants/companies.
6. Audit feature flags, plans, billing, subscription status, trial status, sandbox/live status, and premium module gating.
7. Audit audit logs to confirm all platform-owner actions are logged with user, time, company, target object, before/after values, and reason.
8. Check whether emergency actions such as suspend company, disable feature, and kill switch exist and are safe.
9. Document gaps and implement missing controls with tests before release.

5. Super Admin Dashboard Requirements

The Super Admin dashboard should provide a live platform overview like the screen shown: total companies, users, employees, trials, sandbox accounts, suspended companies, paid subscriptions and MRR.

Metric / Widget	Requirement
Total companies	Count all tenant/company workspaces.
On trial	Count companies on trial and show trial expiry dates.
Sandbox	Count companies running in sandbox/demo mode.
Suspended	Count suspended companies and reasons.
MRR GBP	Monthly recurring revenue from active paid subscriptions.

Total users	Platform-wide user count.
Total employees	Employee records across all companies, respecting safe platform summary rules.
Paid subscriptions	Count active paying customers.
Risk alerts	Failed payments, expiring trials, suspicious access, failed compliance scans, integration failures.

6. Required Super Admin Tabs / Sections

Tab / Section	Purpose	Required Actions
Companies	Manage all tenant companies	View, inspect, suspend, reactivate, assign plan, enable modules, configure sandbox/live mode, export metadata.
Users	Manage platform-wide user accounts	Search users, view tenant memberships, disable access, reset MFA, force logout, view last login.
Plans	Manage subscription plans and feature entitlements	Create/edit plans, set limits, prices, premium modules, trial rules.
Feature Flags	Control platform-wide and tenant-specific flags	Enable/disable module flags globally, by company, by plan, or by user.
Billing	Manage subscriptions, invoices and payment states	Assign plan, override trial, mark paid/free/internal, view MRR.
Audit Log	Immutable platform audit trail	Filter, export, inspect sensitive actions, detect suspicious use.
Security	Manage platform security settings	Designated Super Admin emails, MFA enforcement, sessions, IP restrictions, access policies.
System Health	Monitor integrations and jobs	RTI jobs, email queues, report generation, file storage, backups, AI services.
Emergency Controls	Critical kill switch and incident tools	Disable module globally, suspend company, block login, freeze submissions.

7. Companies Management

Super Admin must be able to manage every company/tenant without entering the normal company admin experience unless explicitly using an audited support/impersonation mode.

Feature	Requirement
Company list	Search, filter and sort by name, status, plan, users, employees, created date, subscription status.
Company profile	View tenant ID, owner, plan, feature entitlements, modules, billing, limits, environment, integrations.
Suspend company	Disable company access with reason and audit log.
Reactivate company	Restore access after review.
Assign/change plan	Move company between plans with audit record.
Set trial expiry	Extend/end trial with reason.
Enable sandbox/live	Control whether company is sandbox/demo, production, or restricted.

Module overrides	Enable/disable specific modules for a company.
Support access	Time-limited, reason-required, fully audited support view.

8. Platform-Wide User Management

Feature	Requirement
User directory	Search all users by name, email, company, role, status, last login.
Membership view	Show which company/companies a user belongs to and their roles in each.
Disable account	Suspend user platform-wide or within a specific company.
Force logout	Invalidate sessions immediately.
MFA reset	Reset MFA only with reason and audit log.
Invite platform operator	Only existing Super Admin owner can add designated platform operators.
Remove platform operator	Revoke Super Admin access immediately.
No silent privilege escalation	Every role elevation requires confirmation, reason, and audit log.

9. Plans, Billing and Feature Entitlement Control

The Super Admin must control commercial access across the platform. Premium modules such as UKVI Compliance Scan, HMRC RTI production submissions, advanced analytics, AI Copilot, bulk exports, and enterprise settings should be gated by plan and feature flags.

Plan Control	Requirement
Plan creation	Create/edit Starter, Growth, Premium, Enterprise, Internal, Trial, Sandbox plans.
Plan limits	Set users, employees, companies, file storage, report downloads, AI usage, payroll runs.
Premium modules	Gate UKVI compliance scan, downloadable reports, RTI production, enterprise admin controls, AI Copilot.
Billing state	Trial, active, past due, cancelled, suspended, internal/free, sandbox.
MRR tracking	Calculate platform MRR in GBP.
Feature override	Grant temporary feature access to a specific company with expiry.
Downgrade rules	Graceful restriction when company exceeds plan limits.

10. Feature Flags and Module Control

Super Admin must be able to turn modules and advanced features on/off globally, by plan, by company, or by specific user where appropriate.

Module / Feature	Global Control Needed
Dashboard	Enable/disable analytics widgets and platform maintenance banners.
Employees	Enable employee database, import/export, sensitive field

	controls.
Leave / Absence	Enable leave module, absence tracking, manager approvals.
Documents	Enable file upload, storage quotas, download permissions.
Time Tracking	Enable timesheets, clock-in/out, approval workflows.
Scheduling	Enable rota/shift module.
Payroll	Enable payroll engine and pay runs by plan/company.
Statutory Pay	Enable SSP/SMP/SPP/SAP/ShPP calculations.
Year-End	Enable P60/P45/year-end reports.
HMRC RTI	Enable sandbox or production RTI by company.
RTI Sync	Enable RTI workflow and submissions only when configured and allowed.
UKVI Compliance	Enable premium compliance module and scans.
Import	Enable bulk import and validation.
Audit Log	Always enabled; export may be plan-gated.
Self-Service	Enable employee self-service portal.
Enterprise	Enable multi-company/enterprise controls.
Performance	Enable goals, reviews, probation tracking.
Policies / Training	Enable policy acknowledgement and training tracking.
HR Analytics	Enable advanced analytics and dashboards.
Data Protection / GDPR Centre	Enable DSAR, retention, consent and data controls.
Security / Trust Badge	Enable security centre and trust badge features.
AI Copilot	Enable AI by plan/company/user and restrict data access scope.

11. Emergency Controls and Kill Switch

Warning

Emergency controls must be protected by MFA re-authentication, confirmation phrase, reason capture, and immutable audit logging. They should be used only for incidents, abuse, payment enforcement, security threats, regulatory risk, or serious system faults.

Emergency Action	Expected Behaviour
Platform maintenance mode	Temporarily prevent non-admin access and show maintenance banner.
Global module kill switch	Disable a module such as HMRC RTI, Payroll, UKVI Scan, AI Copilot across the platform.
Company suspension	Block one company from accessing workspace.
User suspension	Block a user account globally.
Freeze RTI submissions	Prevent live HMRC submissions during incident.
Freeze exports	Disable data exports during data incident.
Disable AI	Turn off AI Copilot globally or for affected companies.
Re-enable action	Require reason, role, MFA, and audit log.

12. Data Isolation and Support Access

Super Admin can manage the platform but must not casually browse customer data. Cross-tenant access should be controlled, minimized, and audited.

Control	Requirement
Tenant isolation	All database queries must scope data to company_id unless using explicit platform-owner endpoints.
Support view	Require reason, company, duration, ticket/reference, and MFA re-authentication.
Impersonation	Avoid full impersonation where possible. If implemented, display persistent banner and log every action.
Read-only first	Default support view should be read-only unless elevated.
Sensitive data masking	Mask bank details, NI numbers, documents and payroll values unless permission and reason exist.
Export restrictions	Super Admin exports must be reason-based and logged.

13. Platform Audit Log Requirements

- Log every Super Admin login, failed access attempt, permission check failure and route/API access denial.
- Log company plan changes, feature flag changes, subscription changes and trial extensions.
- Log user role changes, platform operator additions/removals, MFA resets, force logouts and account suspensions.
- Log emergency kill switch actions, module disabling, RTI freeze, AI freeze, export freeze and re-enable actions.
- Log support access sessions, data viewed, company accessed, duration, reason and user identity.
- Keep audit logs immutable to normal application users and protected from deletion by company admins.

Audit Field	Required
actor_user_id / actor_email	Yes
actor_role	Yes
target_company_id	Where applicable
target_user_id	Where applicable
action	Yes
before_value / after_value	For changes
reason	Required for sensitive actions
ip_address / user_agent	Yes
timestamp	Yes
correlation_id	Yes for troubleshooting

14. Security and Production Hardening

Area	Production Requirement
Authentication	Strong authentication with verified email and MFA.
Authorisation	Server-side requireSuperAdmin middleware on all Super Admin APIs.
Email allowlist	Designated emails only; no company role automatically grants access.
CSRF/XSS	Protect admin mutations and sanitize inputs.

Rate limiting	Limit login and sensitive admin endpoints.
Secrets	Never expose feature flag secrets, payment secrets, API keys, HMRC credentials or customer secrets.
Encryption	Encrypt sensitive credentials and customer secrets at rest.
Backups	Protect backups and ensure restoration does not bypass access controls.
Testing	Add unit, integration, E2E and security tests for access isolation.

15. Recommended Database Models

```

platform_operators
- id
- user_id
- email
- role: platform_owner | platform_admin | platform_support | platform_billing | platform_readonly
- mfa_required
- status: active | suspended | revoked
- created_by
- created_at
- revoked_by
- revoked_at

companies
- id
- name
- status: trial | active | suspended | cancelled | sandbox
- plan_id
- trial_ends_at
- billing_customer_id
- environment: sandbox | production | restricted
- created_at

plans
- id
- name
- price_gbp
- billing_interval
- limits_json
- included_features_json
- premium_features_json

feature_flags
- id
- key
- description
- global_enabled
- plan_rules_json
- company_overrides_json
- user_overrides_json

platform_audit_logs
- id

```

```
- actor_user_id
- actor_email
- action
- target_type
- target_id
- target_company_id
- before_json
- after_json
- reason
- ip_address
- user_agent
- correlation_id
- created_at

support_access_sessions
- id
- platform_operator_id
- company_id
- reason
- ticket_reference
- access_level: read_only | elevated
- started_at
- expires_at
- ended_at
- actions_count
```

16. Recommended API Endpoints

```
GET /api/superadmin/me
GET /api/superadmin/dashboard
GET /api/superadmin/companies
GET /api/superadmin/companies/:companyId
PATCH /api/superadmin/companies/:companyId/status
PATCH /api/superadmin/companies/:companyId/plan
PATCH /api/superadmin/companies/:companyId/features
POST /api/superadmin/companies/:companyId/support-access
GET /api/superadmin/users
PATCH /api/superadmin/users/:userId/status
POST /api/superadmin/users/:userId/force-logout
POST /api/superadmin/users/:userId/reset-mfa
GET /api/superadmin/plans
POST /api/superadmin/plans
PATCH /api/superadmin/plans/:planId
GET /api/superadmin/feature-flags
PATCH /api/superadmin/feature-flags/:flagId
GET /api/superadmin/audit-logs
GET /api/superadmin/billing/overview
POST /api/superadmin/emergency/kill-switch
POST /api/superadmin/emergency/restore
GET /api/superadmin/system-health
```

17. Acceptance Criteria

- Normal users and company admins cannot access /superadmin in the UI or via direct API calls.
- Only designated platform emails with MFA can access the Super Admin portal.
- Removing an email from the Super Admin allowlist immediately blocks access.
- Every Super Admin action writes a platform audit log entry.
- Super Admin can view company list, plan status, trial status, users, employees summary and subscription status.
- Super Admin can suspend/reactivate companies with reason and audit log.
- Super Admin can enable/disable feature flags globally, by plan and by company.
- Premium features are enforced both on frontend and backend.
- Emergency kill switch disables selected modules without breaking the whole app.
- Support access is time-limited, reason-based and audited.
- Tenant data remains isolated unless explicit platform access is used.
- All tests pass and production build/deployment succeeds.

18. Testing Checklist

Test	Expected Result
Visit /superadmin as employee	Access denied.
Visit /superadmin as company admin	Access denied.
Visit /superadmin as designated email without MFA	Prompt/deny until MFA completed.
Call Super Admin API with company admin token	403 forbidden.
Change company plan	Plan changes and audit log records before/after.
Disable UKVI module for one company	Module unavailable for that company only.
Disable feature globally	Feature unavailable across all companies.
Suspend company	Company users cannot access workspace; Super Admin can reactivate.
Use emergency kill switch for RTI	RTI live submissions blocked across platform.
Start support access	Reason required; session expires; actions logged.

19. Full Codex / Developer Prompt

Copy and paste the prompt below into Codex or send it directly to the developer.

You are working on the RealtouchHR SaaS application. Build and/or complete the Super Admin platform-owner control plane as a production-ready feature.

GOAL

Create a secure Super Admin portal for the RealtouchHR platform owner to manage the entire multi-tenant application. This portal is different from Company Admin. Company Admin controls only one company workspace. Super Admin controls the entire platform across all companies, plans, users, billing states, feature flags, security controls, audit logs, sandbox/live environments and emergency controls.

ACCESS ROUTE AND SECURITY

1. Create or verify a separate Super Admin route such as /superadmin or /platform-admin.
2. Do not rely on frontend visibility only. Enforce access on the backend for every page, API and mutation.
3. Only designated emails can access the Super Admin portal. Use a secure allowlist via SUPER_ADMIN_EMAILS and/or a platform_operators database table.
4. Company owners, company admins, HR admins, payroll admins, managers and normal users must not be able to access /superadmin by URL guessing, local storage manipulation, role escalation or direct API calls.
5. Require MFA for Super Admin access. If MFA is not configured, block or require setup before access.
6. Add secure session handling, force logout support and optional IP allowlist support.
7. Log every successful and failed Super Admin access attempt.

AUDIT FIRST

Before implementation, audit the current codebase and produce a gap report covering:

- Existing Super Admin route/page/API if any
- Existing roles and permissions
- Existing route guards and API middleware
- Whether company admins can access any Super Admin endpoint
- Existing company, user, plan, billing and feature flag models
- Existing audit log coverage
- Existing emergency controls
- Existing tenant isolation rules
- Missing security controls and missing tests

REQUIRED SUPER ADMIN FEATURES

Implement the following sections:

1. Dashboard

- Total companies
- Companies on trial
- Sandbox companies
- Suspended companies
- MRR in GBP
- Total platform users
- Total employee records
- Paid subscriptions
- Failed payments, security alerts and integration health alerts

2. Companies

- List/search/filter/sort all companies
- View company profile: tenant ID, owner, users, employees count, plan, status, subscription, feature entitlements, environment, integrations
- Suspend/reactivate company with reason
- Assign/change subscription plan
- Extend/end trial
- Enable sandbox/live/restricted environment
- Enable/disable company modules and feature overrides
- Time-limited audited support access to a company

3. Users

- Platform-wide user directory
- Search by email, name, company, role, status, last login
- View company memberships and roles
- Disable account globally or per company where appropriate
- Force logout
- Reset MFA only with reason and audit log
- Add/remove designated Super Admin operators securely

4. Plans and Billing

- Create/edit plans such as Trial, Starter, Growth, Premium, Enterprise, Internal and Sandbox
- Define limits: users, employees, storage, payroll runs, report downloads, AI usage
- Define included and premium features
- Assign plans to companies
- Track billing state: trial, active, past due, cancelled, suspended, internal/free, sandbox
- Track MRR GBP and paid subscriptions
- Support temporary feature overrides with expiry

5. Feature Flags

- Manage global feature flags
- Manage plan-based flags
- Manage company-specific overrides
- Manage user-specific overrides only where needed
- Feature flags must control both frontend visibility and backend API access
- Include flags for Dashboard, Employees, Leave, Absence, Documents, Time Tracking, Scheduling, Payroll, Statutory Pay, Year-End, HMRC RTI, RTI Sync, UKVI Compliance, Import, Audit Log, Self-Service, Enterprise, Performance, Policies, Training, HR Analytics, Data Protection, GDPR Centre, Security, Trust Badge, Admin, Billing, Settings and AI Copilot

6. Emergency Controls

- Add emergency kill switch capability protected by MFA re-authentication, confirmation phrase and reason capture
- Disable module globally
- Suspend company
- Freeze HMRC RTI live submissions
- Freeze payroll live actions if required
- Freeze data exports during incident
- Disable AI Copilot globally or for affected companies
- Re-enable actions with reason and audit log

7. Platform Audit Logs

- Immutable audit logs for every Super Admin action
- Capture actor, action, target, company, before value, after value, reason, IP, user agent, timestamp and correlation ID
- Audit login attempts, denied access, role changes, plan changes, feature flag changes, emergency actions, support sessions, exports and sensitive data access
- Provide filtering, searching and export for authorised Super Admins only

8. Security and Data Isolation

- Enforce tenant isolation on all normal routes and APIs
- Only platform-owner endpoints may query cross-tenant data
- Support access must be time-limited, reason-required and audited
- Mask sensitive customer data by default: bank details, NI numbers, payroll, documents, HMRC credentials, visa documents, personal documents and secrets
- Do not expose environment variables, API secrets, HMRC credentials or payment secrets in the UI or API responses

9. System Health

- Show health of jobs, queues, email, report generation, file storage, backups, AI services, HMRC RTI integration and payment integration
- Show failed background jobs and retry controls where safe

10. AI Copilot Controls

- Super Admin can enable/disable AI Copilot globally, by plan and by company
- Control whether AI can access company data, employee data, documents, payroll, UKVI, RTI or audit records
- Log AI access where required

DATA MODELS

Add or update models for:

- platform_operators
- companies
- plans
- feature_flags
- company_feature_overrides
- platform_audit_logs
- support_access_sessions
- emergency_actions
- billing_events
- system_health_events

API ENDPOINTS

Create secure /api/superadmin endpoints for dashboard, companies, users, plans, feature flags, billing, audit logs, emergency controls, support access and system health. All endpoints must use requireSuperAdmin middleware and must never trust frontend-only checks.

ACCEPTANCE TESTS

Add automated tests proving:

- Employee cannot access /superadmin
- Company admin cannot access /superadmin
- Company admin cannot call Super Admin APIs
- Designated Super Admin email with MFA can access
- Removing Super Admin designation blocks access
- Plan changes are logged
- Feature flag changes are enforced frontend and backend
- Company suspension blocks company users
- Emergency kill switch blocks selected module actions
- Support access requires reason, expires and logs actions
- Tenant data remains isolated

UI REQUIREMENTS

Match the existing RealtouchHR design: white background, clean cards, purple primary actions, red emergency actions, status badges, searchable tables and clear tabs. Show a visible warning that Super Admin is the platform owner control plane.

DELIVERABLE

Implement the feature safely, run lint/tests/build, and provide a completion report listing:

- What already existed
- What was missing
- What was implemented
- Security controls added
- Tests added
- Any remaining risks or manual setup required such as adding designated Super Admin emails and configuring MFA.

20. Developer Completion Report Template

Section	Developer Must Complete
Existing features found	List what already existed before implementation.
Missing features found	List gaps discovered during audit.
Features implemented	List pages, APIs, models, middleware and tests added.
Security validation	Confirm backend route/API protection and MFA

	enforcement.
Tenant isolation validation	Confirm company data cannot leak between tenants.
Super Admin emails	List where designated emails are configured; do not expose secrets in report.
Tests run	List unit, integration, E2E, build and manual tests.
Remaining risks	List any follow-up actions.